



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE
DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Ingeniería de la Seguridad del Software

Nombre: Mateo Sosa

NRC: 30808

Fecha: May 11, 2026

Contents

07 - Abril - 2026	5
Objetivos de Aprendizaje	5
Meditación	5
Utiliza el Tiempo con Sabiduría	5
Temas de la Materia	5
10 - Abril - 2026	7
Objetivos de Aprendizaje	7
Meditación	7
Seguridad de la información	7
Fundamentos de la seguridad en ingeniería	7
Definiciones	8
Vulnerabilidades, Amenazas, Riesgo, Incidente	8
Fases de Ethical Hacking	8
Tríada CID	10
Marco Legal	10
14 - Abril - 2026	12
Objetivos de Aprendizaje	12
Reflexión	12
Herramientas Tecnológicas	12
Reconocimiento Pasivo OSINT	12
Ethical Hacking	13
Tipos de Registros DNS	13
OWASP (Open Web Application Security Project)	14
OSINT (Open Source Intelligence)	14
16 - Abril - 2026	16
Objetivos de Aprendizaje	16
Meditación	16
Tríada CID	16
Escaneo de puertos y su importancia	16
SIEM (Security Information and Event Management)	16
Herramientas tecnológicas	18
Reconocimiento pasivo	18
Reconocimiento activo	18
21 - Abril - 2026	20
Objetivos de Aprendizaje	20
Meditación	20
Fórmula de la Felicidad	20
CERT / CSIRT	20
Definiciones	20
Actividades	20
SIEM	21
Definiciones	21
Herramientas Tecnológicas	22

23 - Abril - 2026	23
Objetivos de Aprendizaje	23
Meditación	23
Requisitos Funcionales de Ciberseguridad	23
SIEM	23
Funciones	25
Marcas	25
Prestaciones	26
XDR	26
OpenXDR	26
28 - Abril - 2026	28
Objetivos de Aprendizaje	28
Meditación	28
Zona de Confort	28
Requerimientos Funcionales de Seguridad	28
Identificación, Autenticación y Control de Acceso	28
Protección de Sistemas y Comunicaciones	29
Comunicación Segura y Soporte Criptográfico	29
Planes de Contingencia y Mantenimiento	29
Cultura Corporativa y Capacitación	29
FIPS PUB 200	29
Common Criteria	29
Conceptos Importantes	30
05 - Mayo - 2026	31
Objetivos de Aprendizaje	31
Meditación	31
No al Alcohol	31
Amenazas y Vulnerabilidades Más Comunes	31
Modelo STRIDE	32
07 - Mayo - 2026	34
Objetivos de Aprendizaje	34
Meditación	34
Día de la Madre	34
Acrónimos	34
Vulnerabilidades	34

List of Figures

1	Temas de la Materia de Seguridad del Software	6
2	Seguridad de la Información	7
3	Diagrama de Venn sobre el Riesgo	9
4	Triada CID	11
5	Open Web Application Security Project	14
6	Open Source Intelligence	15
7	Representación Gráfica de las Conexiones entre Dispositivos mediante Internet	17

8	Security Information and Event Management	17
9	Diagrama de Funcionamiento SIEM	21
10	Ciberseguridad	24
11	Security Information and Event Management	24
12	Detection, Investigation & Response	27
13	Funciones de un OpenXDR	27
14	Amenazas y Vulnerabilidades en la Ciberseguridad	32
15	Modelo STRIDE y sus Siglas	33

List of Tables

1	Herramientas más utilizadas para analizar vulnerabilidades	12
2	Registros y sus propósitos	13
3	Herramientas de reconocimiento pasivo y su función	18
4	Herramientas de reconocimiento activo y su función	19
6	Funciones de un SIEM y sus beneficios	25
7	Marcas y características de un SIEM	25
8	Prestaciones y descripciones de un SIEM	26

07 - Abril - 2026

Objetivos de Aprendizaje

1. Presentación
2. Macro-Micro Currículum
3. **UNIDAD 1**
 - Fundamentos de la Ingeniería de la Información
4. Práctica de Laboratorio: Análisis de Tráfico entre HTTP vs. HTTPS utilizando *WireShark* en un *VNE*

Meditación

Utiliza el Tiempo con Sabiduría

El tiempo es un recurso no renovable. El tiempo de Dios es perfecto.

- Tiempo Presente
- Tiempo Pasado
- Tiempo Futuro
- **Tiempo Perdido**

Temas de la Materia

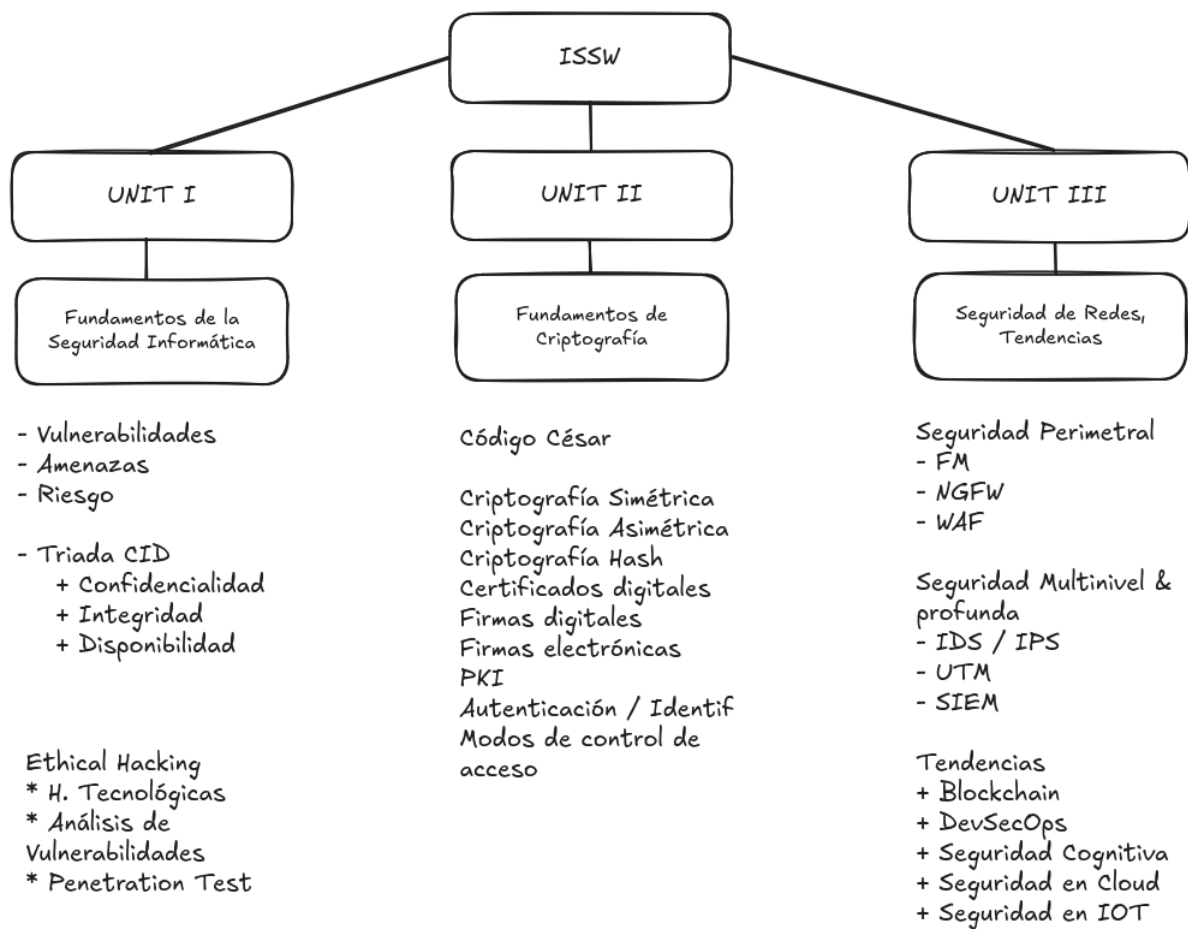


Figure 1: Temas de la Materia de Seguridad del Software

10 - Abril - 2026

Objetivos de Aprendizaje

- Fundamentos de la seguridad en ingeniería
- Definiciones: seguridad informática / ciberseguridad
- Vulnerabilidades, amenazas, riesgo, incidente
- CID, no repudio, autenticación, identificación, trazabilidad, resiliencia
- Marco legal (COIP, Ley de protección de datos)
- Práctica de laboratorio N.º 2: reconocimiento pasivo

Meditación

Sin meditación

Seguridad de la información



Figure 2: Seguridad de la Información

Fundamentos de la seguridad en ingeniería

La seguridad en ingeniería comprende el conjunto de principios, metodologías y controles orientados a proteger sistemas, aplicaciones e infraestructura tecnológica frente a fallos, ataques o accesos no autorizados. Dentro del desarrollo de software y sistemas distribuidos,

la seguridad debe integrarse desde las primeras etapas del ciclo de vida mediante prácticas como el análisis de riesgos, diseño seguro y validación continua (Stallings and Brown 2018).

La incorporación de mecanismos de seguridad permite garantizar la continuidad operativa, proteger la información sensible y reducir el impacto de incidentes tecnológicos. Actualmente, la seguridad en ingeniería se considera un componente transversal que involucra aspectos técnicos, organizacionales y legales para asegurar la confiabilidad de los sistemas digitales (Pfleeger, Pfleeger, and Margulies 2015).

Definiciones

La seguridad informática se enfoca en la protección de sistemas computacionales, redes y datos frente a accesos indebidos, alteraciones o destrucción de la información. Su objetivo principal es preservar la confidencialidad, integridad y disponibilidad de los recursos tecnológicos mediante controles técnicos y administrativos (Whitman and Mattord 2018).

Por otro lado, la ciberseguridad abarca un enfoque más amplio orientado a la protección del ciberespacio, incluyendo redes, servicios digitales, dispositivos conectados y usuarios. Esta disciplina considera amenazas provenientes de internet, ataques cibernéticos y actividades maliciosas que puedan afectar tanto a organizaciones como a individuos (National Institute of Standards and Technology 2018).

Vulnerabilidades, Amenazas, Riesgo, Incidente

Amenazas Eventos o acciones que pueden causar daño a un sistema, de forma intencional o accidental.

Vulnerabilidades Debilidades o fallos en un sistema que pueden ser explotados.

Riesgos Probabilidad de que una amenaza explote una vulnerabilidad y cause impacto.

Una vulnerabilidad es una debilidad presente en un sistema, aplicación o infraestructura que puede ser explotada para comprometer la seguridad. Las amenazas corresponden a eventos o actores capaces de aprovechar dichas debilidades para causar daño, pérdida de información o interrupción de servicios (Anderson 2020).

El riesgo representa la probabilidad de que una amenaza explote una vulnerabilidad y genere consecuencias negativas para la organización. Cuando el evento ocurre y afecta la operación o la información, se considera un incidente de seguridad. La correcta identificación y gestión de estos elementos permite establecer controles preventivos y planes de respuesta adecuados (National Institute of Standards and Technology 2012).

Fases de Ethical Hacking

1. Reconocimiento (pasivo y activo)
2. Escaneo de vulnerabilidades
3. Ganar acceso
4. Mantener acceso
5. Borrar pistas



Figure 3: Diagrama de Venn sobre el Riesgo

Tríada CID

C Confidencialidad

I Integridad

D Disponibilidad

NR No repudio

ID Identificación (username)

AU Autenticación (password)

TZ Trazabilidad

La tríada CID corresponde a los principios de confidencialidad, integridad y disponibilidad. La confidencialidad asegura que únicamente usuarios autorizados accedan a la información; la integridad garantiza que los datos no sean alterados de forma indebida; y la disponibilidad permite que los servicios y recursos estén accesibles cuando se necesiten (Stallings and Brown 2018).

Otros conceptos fundamentales incluyen el no repudio, que impide negar la autoría de una acción; la autenticación, encargada de verificar la identidad de un usuario; y la identificación, mediante la cual un usuario declara quién es. Asimismo, la trazabilidad permite registrar actividades dentro de un sistema para fines de auditoría, mientras que la resiliencia se refiere a la capacidad de recuperarse rápidamente frente a incidentes o ataques (Kim and Solomon 2021).

Marco Legal

COIP Código Orgánico Integral Penal (delitos informáticos y sanciones)

En Ecuador, el marco legal relacionado con la seguridad informática incluye el Código Orgánico Integral Penal (COIP), el cual tipifica delitos informáticos como acceso no autorizado a sistemas, fraude electrónico, interceptación de datos y ataques a infraestructuras tecnológicas (Asamblea Nacional del Ecuador 2021a). Estas disposiciones buscan sancionar actividades ilícitas que afecten la confidencialidad, integridad y disponibilidad de la información.

Además, la Ley Orgánica de Protección de Datos Personales establece principios y obligaciones para el tratamiento adecuado de datos personales por parte de organizaciones públicas y privadas. La normativa regula aspectos como consentimiento, almacenamiento, transferencia y seguridad de la información personal, garantizando los derechos de privacidad de los ciudadanos (Asamblea Nacional del Ecuador 2021b).



Figure 4: Triada CID

14 - Abril - 2026

Objetivos de Aprendizaje

- Herramientas tecnológicas para analizar vulnerabilidades
- Reconocimiento pasivo OSINT

Reflexión

Durante la clase se reflexionó que todos somos humanos y cometemos errores.

Herramientas Tecnológicas

Las herramientas de análisis de vulnerabilidades permiten identificar fallos de seguridad en sistemas operativos, aplicaciones, redes y servicios expuestos. Estas plataformas automatizan procesos de detección mediante escaneos, análisis de configuraciones y evaluación de posibles debilidades que podrían ser explotadas por atacantes (Weidman 2014).

El uso de herramientas especializadas facilita la implementación de pruebas de seguridad preventivas y auditorías periódicas dentro de una organización. Entre las más utilizadas se encuentran soluciones para análisis de red, evaluación web, monitoreo de tráfico y pruebas de penetración (National Institute of Standards and Technology 2008).

Table 1: Herramientas más utilizadas para analizar vulnerabilidades

Herramienta	Tipo	Función principal	Uso común
Nmap	Escáner de red	Descubrimiento de hosts y puertos abiertos	Reconocimiento de red
Wireshark	Analizador de tráfico	Captura y análisis de paquetes	Monitoreo y análisis forense
Nessus	Escáner de vulnerabilidades	Identificación de vulnerabilidades conocidas	Auditorías de seguridad
Metasploit	Framework de pentesting	Explotación controlada de vulnerabilidades	Ethical hacking
Burp Suite	Seguridad web	Análisis y pruebas de aplicaciones web	Evaluación OWASP
OpenVAS	Escáner de seguridad	Detección automatizada de riesgos	Gestión de vulnerabilidades

Reconocimiento Pasivo OSINT

El reconocimiento pasivo consiste en recopilar información sobre un objetivo sin interactuar directamente con sus sistemas. Esta técnica utiliza fuentes públicas como motores de

búsqueda, redes sociales, bases de datos WHOIS y registros DNS para obtener información relevante sobre dominios, infraestructura o usuarios (Mitnick and Simon 2011).

Dentro de los procesos de ciberseguridad, el reconocimiento pasivo permite identificar posibles vectores de ataque antes de realizar pruebas más profundas. Además, reduce la probabilidad de detección debido a que no genera tráfico directo hacia el objetivo analizado (Weidman 2014).

Ethical Hacking

- nmap
- nikto
- Registros DNS
 - dig
 - host
 - nslookup

El ethical hacking, también conocido como hacking ético, consiste en realizar pruebas autorizadas sobre sistemas informáticos con el propósito de identificar vulnerabilidades y fortalecer la seguridad. Los profesionales encargados de estas actividades utilizan metodologías similares a las de un atacante real, pero dentro de un marco legal y controlado (EC-Council 2018).

Las pruebas de penetración incluyen fases como reconocimiento, análisis, explotación y elaboración de reportes técnicos. El objetivo principal es evaluar el nivel de exposición de una organización y proponer medidas correctivas que permitan reducir riesgos de seguridad (Walker 2021).

Tipos de Registros DNS

Los registros DNS son entradas almacenadas en servidores de nombres que permiten asociar dominios con direcciones IP y otros servicios relacionados. Estos registros facilitan la localización de recursos en internet y el funcionamiento adecuado de servicios web y correo electrónico (Alzahrani 2020).

Entre los registros más utilizados se encuentran el registro A, que relaciona un dominio con una dirección IPv4; el registro AAAA para IPv6; el registro MX para servidores de correo; el registro CNAME para alias de dominios; y el registro TXT, utilizado frecuentemente para validaciones y políticas de seguridad (Mockapetris 1987).

Table 2: Registros y sus propósitos

Registro	Propósito	Ejemplo
A	Asocia dominio con IPv4	ejemplo.com → 192.168.1.1
AAAA	Asocia dominio con IPv6	ejemplo.com → 2001:db8::1
MX	Define servidores de correo	mail.ejemplo.com
CNAME	Crea alias de dominio	www.ejemplo.com → ejemplo.com
TXT	Información adicional o validaciones	SPF, DKIM, verificaciones

Registro	Propósito	Ejemplo
NS	Define servidores DNS autoritativos	ns1.ejemplo.com

OWASP (Open Web Application Security Project)

OWASP es una organización internacional enfocada en mejorar la seguridad del software y las aplicaciones web. Proporciona documentación, herramientas y estándares abiertos para ayudar a desarrolladores y profesionales de seguridad a identificar y mitigar riesgos comunes en aplicaciones (OWASP Foundation 2021).

Uno de sus recursos más reconocidos es el OWASP Top 10, una lista de las vulnerabilidades web más críticas, incluyendo inyección SQL, control de acceso inseguro y fallos criptográficos. Este proyecto sirve como referencia para auditorías de seguridad y buenas prácticas de desarrollo seguro (Stuttard and Pinto 2011).



Figure 5: Open Web Application Security Project

OSINT (Open Source Intelligence)

OSINT corresponde al proceso de recopilación y análisis de información obtenida de fuentes públicas y abiertas. Estas fuentes incluyen redes sociales, sitios web, publicaciones académicas, registros públicos y plataformas digitales accesibles sin restricciones (Haddad 2019).

En ciberseguridad, OSINT se utiliza para investigaciones, análisis de amenazas y reconocimiento previo a auditorías de seguridad. La información obtenida puede ayudar a identificar infraestructura tecnológica, usuarios expuestos y posibles riesgos asociados a una organización (Rao 2023).



Figure 6: Open Source Intelligence

16 - Abril - 2026

Objetivos de Aprendizaje

- Herramientas tecnológicas para garantizar la tríada CID/CIA
- Comprender el escaneo de puertos y su importancia

Meditación

Se recordó el terremoto en Ecuador del 16 de abril de 2016.

Tríada CID

Confidencialidad Protección contra accesos no autorizados

Integridad Información no alterada

Disponibilidad Acceso cuando se requiera

NR No repudio

ID Identificación

AU Autenticación

TZ Trazabilidad

Resiliencia Capacidad de recuperación ante fallos

Escaneo de puertos y su importancia

El escaneo de puertos es una técnica utilizada para identificar servicios disponibles y puertos abiertos en un sistema o red. Este proceso permite conocer qué aplicaciones están ejecutándose en un host y detectar posibles vulnerabilidades asociadas a servicios expuestos (Weidman 2014).

La importancia del escaneo de puertos radica en que constituye una de las primeras etapas dentro de auditorías de seguridad y pruebas de penetración. Herramientas especializadas permiten identificar configuraciones inseguras, servicios innecesarios y posibles vectores de ataque que podrían comprometer la infraestructura tecnológica (National Institute of Standards and Technology 2008).

SIEM (Security Information and Event Management)

Los sistemas SIEM permiten recopilar, correlacionar y analizar eventos de seguridad provenientes de diferentes dispositivos y aplicaciones dentro de una organización. Estas plataformas centralizan registros de actividad para facilitar la detección temprana de incidentes y amenazas cibernéticas (Chuvakin, Schmidt, and Phillips 2013).

Además de monitorear eventos en tiempo real, los SIEM ayudan a automatizar alertas, generar reportes y mantener trazabilidad sobre actividades sospechosas. Su implementación es fundamental para fortalecer la capacidad de respuesta ante incidentes y cumplir con normativas de seguridad y auditoría (Bejtlich 2013).



Figure 7: Representación Gráfica de las Conexiones entre Dispositivos mediante Internet



Figure 8: Security Information and Event Management

Herramientas tecnológicas

La tríada CID, también conocida como CIA por sus siglas en inglés, representa los principios fundamentales de la seguridad de la información: confidencialidad, integridad y disponibilidad. Para garantizar estos principios se utilizan herramientas tecnológicas enfocadas en cifrado, monitoreo, autenticación, control de acceso y respaldo de información (Stallings and Brown 2018).

Las organizaciones implementan soluciones de seguridad que permiten proteger datos sensibles, detectar actividades maliciosas y asegurar la continuidad operativa. Entre estas herramientas se incluyen sistemas de monitoreo de eventos, plataformas criptográficas y aplicaciones de análisis de red utilizadas tanto en entornos empresariales como académicos (Kim and Solomon 2021).

Reconocimiento pasivo

El reconocimiento pasivo recopila información sobre un objetivo sin interactuar directamente con sus sistemas. Estas herramientas permiten obtener información relacionada con dominios, registros DNS, infraestructura y presencia digital utilizando fuentes públicas y abiertas (Haddad 2019).

Table 3: Herramientas de reconocimiento pasivo y su función

Herramienta	Tipo	Función principal	Uso común
<code>nslookup</code>	Consulta DNS	Obtiene información de registros DNS	Resolución de dominios
<code>host</code>	Consulta DNS	Traduce dominios a IP y viceversa	Verificación rápida DNS
<code>dig</code>	Consulta DNS avanzada	Consulta detallada de registros DNS	Diagnóstico DNS
<code>whoisdomaintool</code>	OSINT	Consulta información WHOIS de dominios	Información de registro
<code>DNSDumpster</code>	OSINT DNS	Mapea infraestructura DNS	Reconocimiento de dominios
<code>dnsenum</code>	Enumeración DNS	Descubre subdominios y registros	Auditorías DNS
<code>dnsrecon</code>	Reconocimiento DNS	Recolección automatizada DNS	Pentesting
Google dorks	OSINT	Búsquedas avanzadas indexadas	Exposición de información

Reconocimiento activo

El reconocimiento activo implica interacción directa con el objetivo mediante escaneos y consultas sobre sistemas y servicios disponibles. Estas herramientas permiten identificar

hosts activos, puertos abiertos, sistemas operativos y configuraciones vulnerables (Weidman 2014).

Las técnicas de reconocimiento activo son ampliamente utilizadas en pruebas de penetración y auditorías de seguridad para evaluar el nivel de exposición de una infraestructura tecnológica (EC-Council 2018).

Table 4: Herramientas de reconocimiento activo y su función

Herramienta / Técnica	Función principal	Información obtenida	Uso común
nmap	Escaneo de red	Hosts, puertos y servicios	Reconocimiento de red
IP vecinas	Descubrimiento de hosts	Equipos cercanos en red	Mapeo de infraestructura
Sistemas operativos	Fingerprinting	Sistema operativo remoto	Análisis de objetivos
Protocolos	Detección de servicios	Protocolos activos	Auditoría de servicios
Puertos abiertos	Escaneo de puertos	Servicios expuestos	Identificación de riesgos
scanme.org	Entorno de pruebas	Simulación de escaneos	Prácticas legales
enum4linux	Enumeración SMB	Usuarios y recursos compartidos	Auditoría Windows/Linux
Criptografía	Protección de datos	Integridad y confidencialidad	Seguridad de información
OpenSSL	Herramienta criptográfica	Certificados y cifrado	Gestión TLS/SSL
GPG (GNU Privacy Guard)	Cifrado y firmas digitales	Protección y autenticación	Seguridad de archivos

21 - Abril - 2026

Objetivos de Aprendizaje

1. Herramienta Tecnológica para asegurar la triada CID
2. *Ethical Hacking*
 - Reconocimiento Pasivo
 - Google Dorks
 - Comandos Linux
 - Reconocimiento Activo
 - nmap
 - enum4linux
3. Escaneo
 - Herramientas Tecnológicas
 - nmap --vulnerability
 - SIEM
 - UTM
 - NGFM
 - OpenXDR
 - Equipos Organizacionales
 - SOC
 - CERT/CSIRT

Meditación

Fórmula de la Felicidad

$$F = M + V + CA$$

F Felicidad

M Metas

V Vínculos

CA Cualidades Afectivas

CERT / CSIRT

Equipos de Respuesta a Incidentes Informáticos.

Servicios Proactivos, Preventivos y Correctivos

Definiciones

CERT Computer Emergency Response Team

CSIRT Computer Security Incident Response Team

SOC Security Operation Center

Actividades

- Análisis de Vulnerabilidades
- Inteligencia de Amenazas
- Operativos

- Software Especializado
 - * Shodan
- Hardware Especializado
 - * SIEM
 - * UTM
 - * NGFW
 - * XDR

SIEM

1. Estructura de un SIEM
2. Marcas
3. Costos
4. Funcionalidades

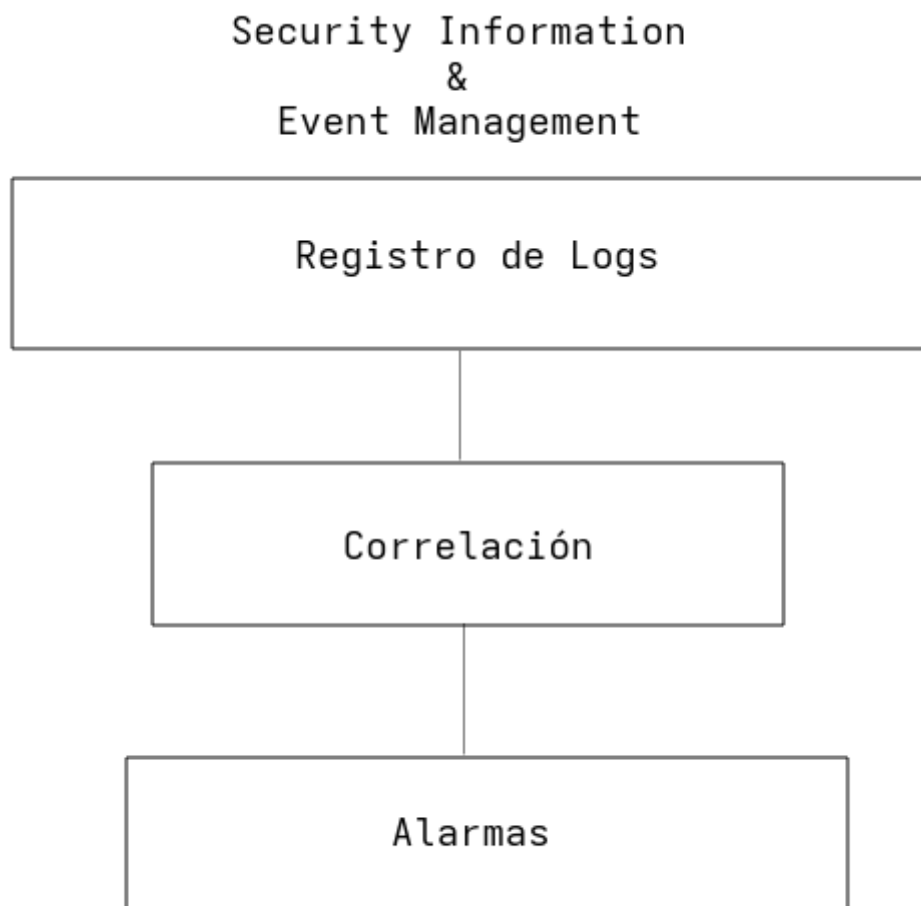


Figure 9: Diagrama de Funcionamiento SIEM

Definiciones

SIEM Security Information & Event Management

Herramientas Tecnológicas

Concepto	Tipo	Función principal	Ejemplo
SOC	Organizativo	Monitoreo continuo de seguridad	Splunk
CSIRT	Organizativo	Respuesta a incidentes	CERT-EU
SIEM	Tecnológico	Recolección y correlación de logs	IBM QRadar
OpenXDR	Tecnológico	Detección y respuesta integrada	Integración de múltiples fuentes
UTM	Tecnológico	Seguridad perimetral todo-en-uno	FortiGate
NGFW	Tecnológico	Firewall avanzado con inspección profunda	Palo Alto Networks NGFW

23 - Abril - 2026

Objetivos de Aprendizaje

1. Requisitos Funcionales de Ciberseguridad
2. Herramientas Tecnológicas
 - SIEM
 - Funciones
 - Marcas
 - Prestaciones
 - XDR
 - OpenXDR
3. Práctica de Laboratorio

Meditación

$$F = RC + VP + AC + AF + GV$$

F Felicidad

RC Relaciones de Calidad

VP Vida con Propósito

AC Actitud

AF Actividad Física

AS Afán de Servicio

GV Generosidad de Vida

Requisitos Funcionales de Ciberseguridad

Los requisitos funcionales de ciberseguridad definen las capacidades y controles que un sistema debe implementar para proteger la información y garantizar operaciones seguras. Estos requisitos incluyen autenticación, autorización, cifrado, monitoreo, auditoría y mecanismos de respuesta ante incidentes (Stallings and Brown 2018).

La definición adecuada de requisitos funcionales permite integrar la seguridad desde las primeras etapas del desarrollo de software y administración de infraestructura. Además, contribuye al cumplimiento normativo y a la reducción de riesgos asociados a amenazas informáticas (National Institute of Standards and Technology 2018).

SIEM

Los sistemas SIEM (Security Information and Event Management) permiten centralizar registros de eventos y actividades provenientes de diferentes dispositivos, servidores y aplicaciones dentro de una organización. Estas plataformas facilitan el monitoreo continuo, la correlación de eventos y la detección temprana de incidentes de seguridad (Chuvakin, Schmidt, and Phillips 2013).

La implementación de soluciones SIEM mejora la capacidad de análisis y respuesta frente a amenazas, permitiendo generar alertas automáticas, reportes de auditoría y trazabilidad sobre eventos críticos dentro de la infraestructura tecnológica (Bejtlich 2013).



Figure 10: Ciberseguridad



Figure 11: Security Information and Event Management

Funciones

Las plataformas SIEM cumplen funciones relacionadas con la recolección, almacenamiento y análisis de registros de seguridad. También permiten correlacionar eventos provenientes de múltiples fuentes para detectar comportamientos sospechosos o actividades maliciosas (Kim and Solomon 2021).

Entre sus funciones principales destacan el monitoreo en tiempo real, generación de alertas, análisis forense, cumplimiento normativo y automatización de respuestas frente a incidentes de seguridad (National Institute of Standards and Technology 2008).

Table 6: Funciones de un SIEM y sus beneficios

Función	Descripción	Beneficio
Recolección de logs	Centraliza registros de múltiples dispositivos	Visibilidad unificada
Correlación de eventos	Relaciona eventos sospechosos	Detección de amenazas
Monitoreo en tiempo real	Supervisa actividad continuamente	Respuesta rápida
Generación de alertas	Notifica incidentes críticos	Prevención de ataques
Auditoría y reportes	Genera evidencia y trazabilidad	Cumplimiento normativo

Marcas

Existen diferentes soluciones SIEM utilizadas en entornos empresariales y académicos. Estas plataformas varían en funcionalidades, escalabilidad y compatibilidad con diferentes infraestructuras tecnológicas (Splunk Inc. 2024).

Algunas herramientas SIEM comerciales y de código abierto permiten integrar monitoreo avanzado, análisis basado en inteligencia artificial y automatización de procesos de seguridad (IBM Corporation 2024).

Table 7: Marcas y características de un SIEM

Marca	Tipo	Características principales
Splunk	Comercial	Análisis avanzado y monitoreo en tiempo real
IBM QRadar	Comercial	Correlación de eventos y detección de amenazas
ArcSight	Comercial	Gestión centralizada de eventos
Wazuh	Open Source	Monitoreo y análisis de seguridad
Elastic SIEM	Open Source	Integración con Elastic Stack

Prestaciones

Las prestaciones de un sistema SIEM dependen de su capacidad para procesar grandes volúmenes de información y detectar amenazas en tiempo real. Estas plataformas permiten mejorar la visibilidad sobre la infraestructura tecnológica y fortalecer la capacidad de respuesta ante incidentes (Chuvakin, Schmidt, and Phillips 2013).

Entre las prestaciones más relevantes se encuentran la automatización de alertas, integración con herramientas externas, análisis de comportamiento y generación de reportes personalizados para auditorías y cumplimiento regulatorio (Bejtlich 2013).

Table 8: Prestaciones y descripciones de un SIEM

Prestación	Descripción
Escalabilidad	Manejo de grandes volúmenes de eventos
Automatización	Respuestas automáticas ante incidentes
Integración	Compatibilidad con múltiples herramientas
Inteligencia de amenazas	Identificación de patrones maliciosos
Visualización	Paneles y dashboards interactivos

XDR

XDR (Extended Detection and Response) es una tecnología de seguridad que integra información proveniente de diferentes capas de la infraestructura tecnológica, incluyendo endpoints, redes, servidores y aplicaciones. Su objetivo es mejorar la detección y respuesta frente a amenazas avanzadas mediante análisis centralizado y automatización (Palo Alto Networks 2023).

A diferencia de soluciones tradicionales, XDR proporciona correlación de datos entre múltiples fuentes para identificar ataques complejos y reducir tiempos de respuesta. Esto permite mejorar la eficiencia operativa de los equipos de seguridad y fortalecer la protección organizacional (CrowdStrike 2023).

OpenXDR

OpenXDR es un enfoque abierto para soluciones XDR que busca integrar herramientas de diferentes fabricantes mediante estándares y APIs interoperables. Esta arquitectura facilita la comunicación entre plataformas de seguridad y permite centralizar eventos provenientes de distintos sistemas (OpenXDR Alliance 2024).

El modelo OpenXDR ofrece flexibilidad y escalabilidad, permitiendo a las organizaciones adaptar sus soluciones de seguridad sin depender exclusivamente de un proveedor específico. Además, mejora la capacidad de automatización y análisis de amenazas en entornos híbridos y distribuidos (Gartner Research 2023).



Figure 12: Detection, Investigation & Response

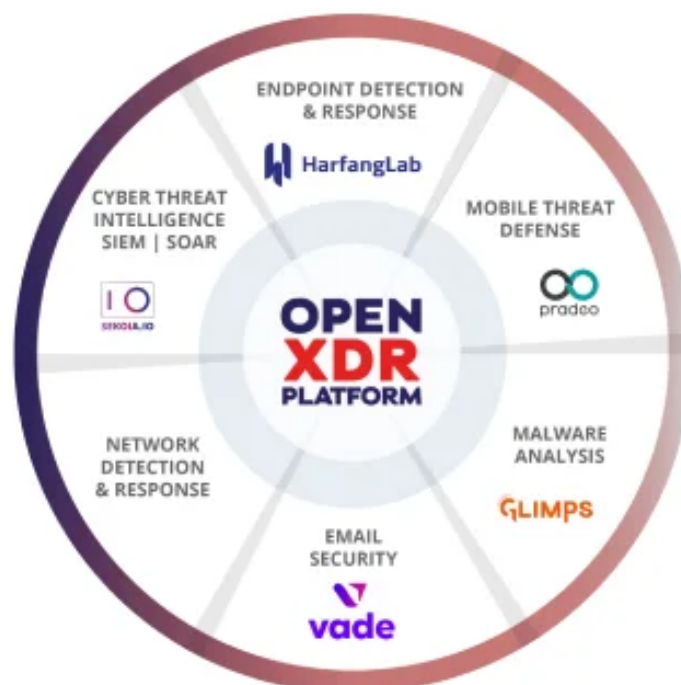


Figure 13: Funciones de un OpenXDR

28 - Abril - 2026

Objetivos de Aprendizaje

1. Requerimientos Funcionales de Seguridad de la Información
 - Introducción
 - Topología de Red
 - Varios Mecanismos
 - * Organizacionales
 - SDC
 - CERT
 - * Tecnologías
 - SIEM
 - XDR
 - OpenXDR
 - NIST
 - CyberSecurity Framework
 - Resoluciones
 - FIPS
 - Identificación
 - Autenticación
 - Control de Acceso
2. Práctica de Laboratorio

Meditación

Zona de Confort

En el 2006, el doctor salió a hacer un tema doctoral. Para ello, necesitó las escrituras de la casa para poder respaldar que iba a volver a casa. Para ese momento, él era decano de la facultad y estaba en su zona de confort.

El doctor decidió salir de su zona de confort y realizar su doctorado. Pasó muchos días en los que tuvo que hacer sus labores para doctorado, dando a veces malos resultados. Sin embargo, apenas volvió con su doctorado, las cosas mejoraron para él.

1. Zona de Confort
2. Zona de Aprendizaje
3. Zona de Pánico
4. Zona Mágica
5. Zona de Crecimiento y Desarrollo

Requerimientos Funcionales de Seguridad

NIST National Institute of Standards and Technology

FIPS Federal Information Processing Standards

Identificación, Autenticación y Control de Acceso

Es necesario identificar y autenticar a los usuarios, y verificar a qué activos de información se tiene acceso.

Protección de Sistemas y Comunicaciones

Es necesario monitorear, controlar y proteger las comunicaciones organizacionales con el mundo externo y utilizar las diferentes técnicas para asegurar la seguridad de la información y de los sistemas de información.

Comunicación Segura y Soporte Criptográfico

En caso de requerir comunicación segura, debe utilizarse algoritmos criptográficos seguros y realizar una administración segura de las llaves criptográficas.

Planes de Contingencia y Mantenimiento

Las organizaciones deben:

1. establecer planes de emergencias, operaciones de respaldo y respuestas post-desastre, y
2. dar mantenimiento periódico de los sistemas y llevar un control de ellas

Cultura Corporativa y Capacitación

Las organizaciones deben:

1. tener una cultura organizacional apegado a los conceptos de seguridad y
2. capacitar al personal en temas de seguridad (tareas a realizar y responsabilidades)

FIPS PUB 200

- Medidas técnicas
 - Identificación y autenticación
 - Control de acceso
 - Protección de sistemas y comunicaciones
 - Integridad de sistemas e información
- Controles y procedimientos administrativos
 - Cultura empresarial y capacitación
 - Auditoría y rendición de cuentas
 - Certificación, acreditación y evaluación de seguridad
 - Planes de contingencia
 - Protección física
 - Evaluación de riesgos
 - Mantenimiento
- Medidas técnicas y administrativas
 - Manejo de configuraciones
 - Respuesta a incidentes
 - Protección de medios (datos)

Common Criteria

- Requerimientos Funcionales de Seguridad
 - Identificación y autenticación
 - Soporte criptográfico

- Administración de seguridad
- Protección del producto y funciones de seguridad
- Comunicación
- Privacidad
- Canales
- Protección de datos de usuario

Conceptos Importantes

Identification Proceso mediante el cual un usuario declara su identidad dentro de un sistema, generalmente ingresando un nombre de usuario o identificador.

Authentication Proceso de verificación de identidad donde el sistema valida que el usuario es realmente quien dice ser, normalmente mediante contraseñas, tokens, biometría o autenticación multifactor.

Authorization Proceso que determina los permisos y privilegios que posee un usuario autenticado para acceder a recursos, archivos o funcionalidades específicas.

Auditing Registro y monitoreo de actividades realizadas dentro de un sistema para fines de supervisión, análisis forense y cumplimiento de políticas de seguridad.

Accounting Proceso de recopilación y almacenamiento de información relacionada con el uso de recursos y actividades de los usuarios, incluyendo tiempos de acceso, consumo de recursos y acciones ejecutadas.

05 - Mayo - 2026

Objetivos de Aprendizaje

1. Amenazas y Vulnerabilidades Más Comunes
2. Taller: Tipos de Malware
3. Modelo **STRIDE**

Meditación

No al Alcohol

La meditación consistía en hacer reflexionar a los estudiantes sobre el consumo desmedido del alcohol.

La primera historia cuenta sobre un chico de la universidad politécnica que salió a jugar fútbol pero, por la mala compañía, terminó emborrachándose y, finalmente, en una calle sin salida, vomitado.

Amenazas y Vulnerabilidades Más Comunes

Las amenazas y vulnerabilidades representan uno de los principales riesgos para la seguridad de los sistemas informáticos. Una amenaza corresponde a cualquier acción o evento capaz de comprometer la confidencialidad, integridad o disponibilidad de la información, mientras que una vulnerabilidad es una debilidad que puede ser explotada por un atacante (Stallings and Brown 2018).

La identificación de amenazas y vulnerabilidades permite implementar controles preventivos y mecanismos de mitigación adecuados. Entre los riesgos más frecuentes se encuentran ataques de malware, phishing, vulnerabilidades web, configuraciones inseguras y accesos no autorizados (OWASP Foundation 2021).

Amenaza / Vulnerabilidad	Descripción	Impacto principal	Ejemplo común
Malware	Software malicioso diseñado para dañar sistemas	Pérdida de información	Ransomware
Phishing	Suplantación de identidad mediante mensajes falsos	Robo de credenciales	Correos fraudulentos
Inyección SQL	Manipulación de consultas a bases de datos	Acceso no autorizado	Formularios vulnerables
Contraseñas débiles	Uso de claves inseguras o repetidas	Compromiso de cuentas	Password123
Configuración insegura	Parámetros incorrectos en sistemas o servidores	Exposición de servicios	Puertos abiertos

Amenaza / Vulnerabilidad	Descripción	Impacto principal	Ejemplo común
Ataques DoS/DDoS	Saturación de recursos de red o servidores	Interrupción del servicio	Tráfico masivo
Vulnerabilidades de software	Errores presentes en aplicaciones	Ejecución de código malicioso	Software sin actualizar
Ingeniería social	Manipulación psicológica de usuarios	Robo de información	Llamadas fraudulentas



Figure 14: Amenazas y Vulnerabilidades en la Ciberseguridad

Modelo STRIDE

El modelo STRIDE es una metodología desarrollada por Microsoft para identificar y clasificar amenazas de seguridad en sistemas y aplicaciones. Este modelo permite analizar riesgos desde diferentes perspectivas y facilitar el diseño de controles de seguridad durante el desarrollo de software (Shostack 2014).

STRIDE agrupa las amenazas en seis categorías: suplantación de identidad (Spoofing), alteración de información (Tampering), repudio (Repudiation), divulgación de información (Information Disclosure), denegación de servicio (Denial of Service) y elevación de

privilegios (Elevation of Privilege). Estas categorías ayudan a evaluar vulnerabilidades potenciales y fortalecer la arquitectura de seguridad (Howard and Lipner 2006).

Categoría	Descripción	Ejemplo
Spoofing	Suplantación de identidad	Robo de credenciales
Tampering	Modificación no autorizada de datos	Alteración de archivos
Repudiation	Negación de acciones realizadas	Eliminación de registros
Information Disclosure	Exposición de información sensible	Fuga de datos
Denial of Service	Interrupción de servicios	Saturación de servidores
Elevation of Privilege	Obtención de permisos elevados	Acceso administrador

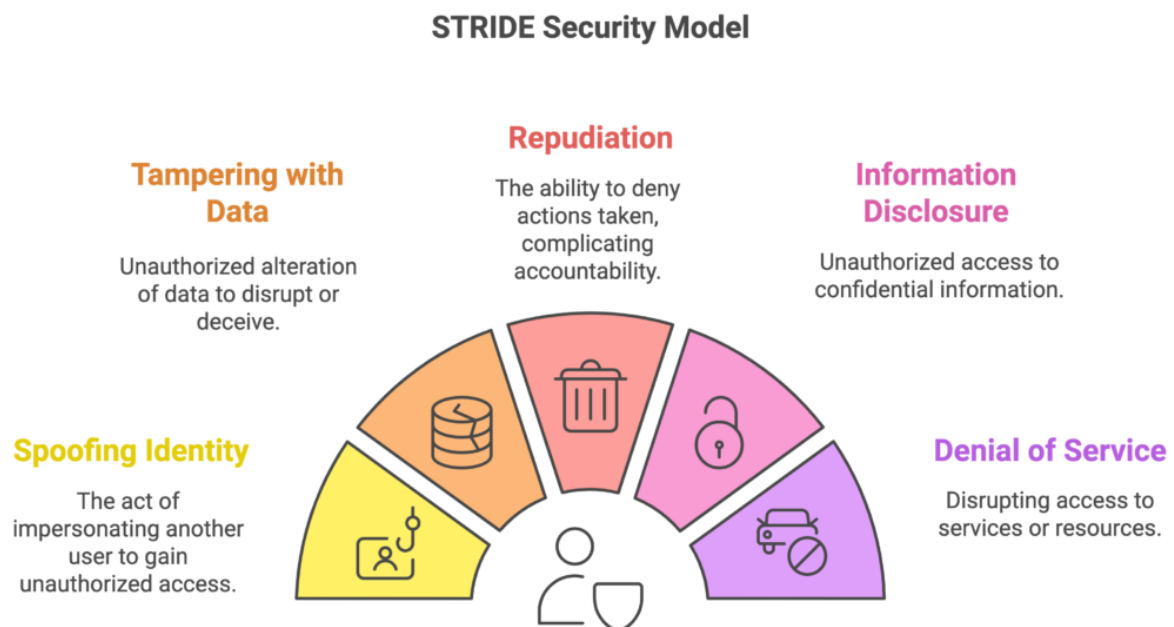


Figure 15: Modelo STRIDE y sus Siglas

07 - Mayo - 2026

Objetivos de Aprendizaje

1. Amenazas y Vulnerabilidades Más Comunes
2. Taller: Identificación de las Vulnerabilidades
 - CVSS

Meditación

Día de la Madre

A la madre se la debe honrar y respetar. Es una persona muy honrada que siempre está dispuesta a ayudar.

El profundo amor de una madre es inmedible.

Acrónimos

OWASP Open Web Application Security Project

CVSS Common Vulnerability Scoring System

DVWA Damn Vulnerable Web Application

OWASP ZAP (Open Web Application Security Project) - Zed Attack Proxy

Vulnerabilidades

- Falta de Parches de un Sistema Operativo
- Vulnerabilidades de Aplicaciones Web
- Insercion de Código SOC

- Alzahrani, Abdullah. 2020. *DNS Security Management*. Springer.
- Anderson, Ross. 2020. *Security Engineering: A Guide to Building Dependable Distributed Systems*. 3rd ed. Wiley.
- Asamblea Nacional del Ecuador. 2021a. "Codigo Organico Integral Penal Del Ecuador."
- . 2021b. "Ley Organica de Proteccion de Datos Personales."
- Bejtlich, Richard. 2013. *The Practice of Network Security Monitoring*. No Starch Press.
- Chuvakin, Anton, Kevin Schmidt, and Chris Phillips. 2013. *Logging and Log Management: The Authoritative Guide to Understanding the Concepts Surrounding Logging and Log Management*. Syngress.
- CrowdStrike. 2023. "What Is XDR?"
- EC-Council. 2018. *Ethical Hacking and Countermeasures*. Cengage Learning.
- Gartner Research. 2023. "Emerging Trends in XDR Platforms."
- Haddad, Nihad A. 2019. *Open Source Intelligence Methods and Tools*. Apress.
- Howard, Michael, and Steve Lipner. 2006. *The Security Development Lifecycle*. Microsoft Press.
- IBM Corporation. 2024. "IBM QRadar SIEM Documentation."
- Kim, David, and Michael Solomon. 2021. *Cybersecurity Fundamentals*. Jones & Bartlett Learning.
- Mitnick, Kevin, and William Simon. 2011. *The Art of Deception*. Wiley.
- Mockapetris, Paul. 1987. "Domain Names - Concepts and Facilities."
- National Institute of Standards and Technology. 2008. "Technical Guide to Information Security Testing and Assessment." NIST Special Publication 800-115.
- . 2012. "Computer Security Incident Handling Guide." NIST Special Publication 800-61.
- . 2018. "Framework for Improving Critical Infrastructure Cybersecurity." NIST.
- OpenXDR Alliance. 2024. "OpenXDR Architecture and Integration."
- OWASP Foundation. 2021. "OWASP Top 10: The Ten Most Critical Web Application Security Risks."
- Palo Alto Networks. 2023. "Extended Detection and Response (XDR)."
- Pfleeger, Charles P., Shari Lawrence Pfleeger, and Jonathan Margulies. 2015. *Security in Computing*. 5th ed. Prentice Hall.
- Rao, Prashant. 2023. *Practical OSINT Techniques*. Packt Publishing.
- Shostack, Adam. 2014. *Threat Modeling: Designing for Security*. Wiley.
- Splunk Inc. 2024. "Splunk Enterprise Security Overview."
- Stallings, William, and Lawrie Brown. 2018. *Computer Security: Principles and Practice*. 4th ed. Pearson.
- Stuttard, Dafydd, and Marcus Pinto. 2011. *The Web Application Hacker's Handbook*. Wiley.
- Walker, Matt. 2021. *CEH Certified Ethical Hacker All-in-One Exam Guide*. McGraw-Hill.
- Weidman, Georgia. 2014. *Penetration Testing: A Hands-on Introduction to Hacking*. No Starch Press.
- Whitman, Michael, and Herbert Mattord. 2018. *Principles of Information Security*. 6th ed. Cengage Learning.